

Лекция 04



Проектирование защитных механизмов

**Как превратить угрозу и требование в обоснованное
решение, которое потом можно проверить?**

Факультет компьютерных наук

Бакалаврская образовательная программа 09.03.04 «Программная инженерия» · 3 курс

Дисциплина «Разработка безопасного программного обеспечения» · 2026/2027 учебный год



После лекции вы сможете

2 / 50

- 1** записать проектное решение D^* с контекстом, обоснованием, предположениями и ограничениями
- 2** сформулировать будущую проверку выбранного механизма
- 3** найти разрыв в цепочке контрпримером и обоснованно уточнить решение



Секция 1

От угрозы к проектному решению

Найти угрозу недостаточно: нужно выбрать и обосновать способ обеспечить свойство



Одна цифра – другой документ

4 / 50

First American Financial, 2019



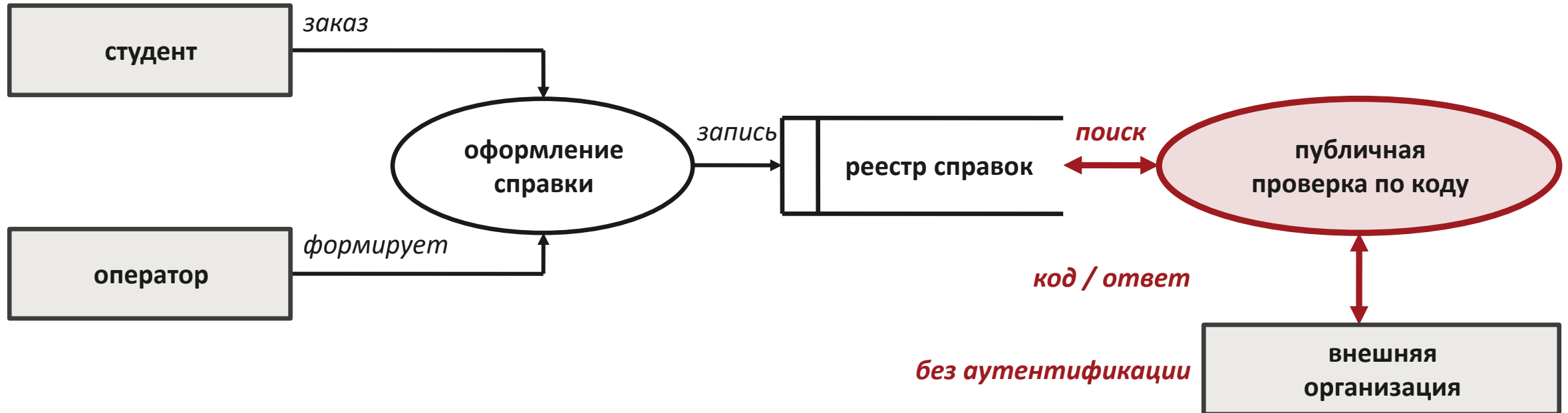
Какое проектное решение должно было сделать такой переход бесполезным или невозможным?

Источник: KrebsOnSecurity, 24.05.2019



Учебный объект: сервис справок

5 / 50



Т-01 – внешний участник перебирает коды проверки и получает сведения из чужих справок

АКТИВ

персональные данные; конфиденциальность факта выдачи справки

ПОСЛЕДСТВИЕ

массовое раскрытие сведений из чужих справок



Требование уже есть. Способ обеспечения – ещё нет

6 / 50

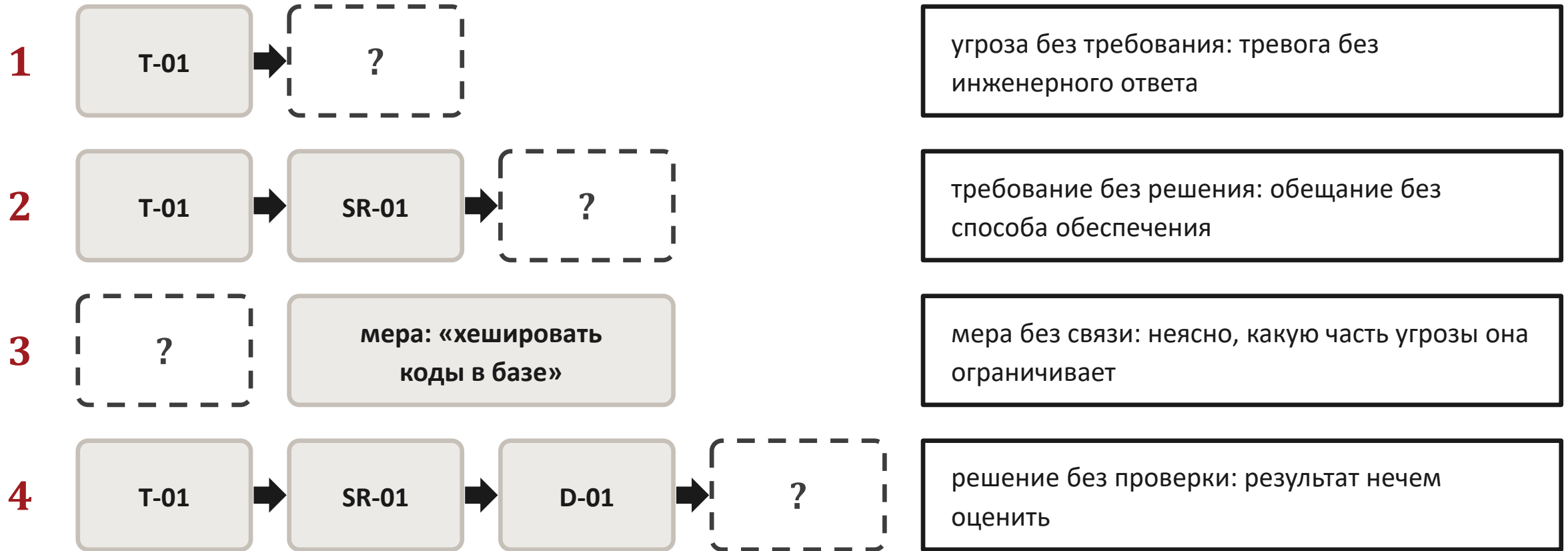


Проектирование безопасности – выбор и обоснование архитектурных и реализационных способов обеспечения требований безопасности с учётом приоритетных угроз, предположений и ограничений продукта.



Где цепочка может разорваться?

7 / 50

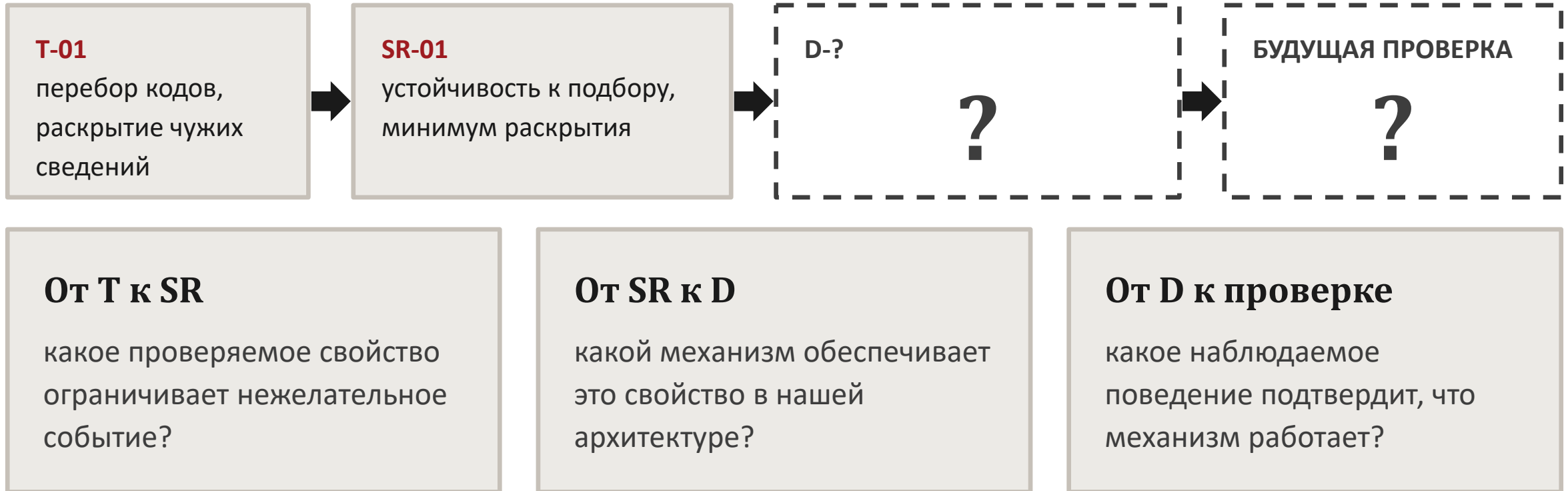


**Идентификаторы и стрелки
не заменяют смысловой связи**



Читаем цепочку от угрозы к проверке

8 / 50



Центральный вопрос: как ограничено значимое событие?



Секция 2

Проектное решение и его поля

Решение должно сохранять не только выбор, но и логику этого выбора



Название меры – ещё не проектное решение

10 / 50

Так часто выглядит «решение» в проекте

«Использовать
HTTPS»

«Добавить CAPTCHA»

«Логировать
операции»

Чего не хватает, чтобы это стало проектным решением?

какое свойство
обеспечивает?

где применяется
механизм?

при каких условиях
работает?

что остаётся
за границей?

Мера может быть полезной, но её название
не объясняет способ обеспечения свойства



Что такое проектное решение безопасности

11 / 50

Проектное решение безопасности

– зафиксированный инженерный выбор способа обеспечения свойства безопасности. В проекте решение получает устойчивый идентификатор D-* и содержит контекст, выбранную защитную меру, обоснование, существенные предположения и ограничения, связи с T-* и SR-*, а также будущую проверку.

ЗАЩИТНАЯ МЕРА

механизм, ограничение, настройка или проверка, которые реализуют или поддерживают требуемое свойство безопасности. Мера входит в проектное решение, но не заменяет его обоснование и фиксацию.

D-* СОДЕРЖИТ

мера:
что применяем

почему

где

при каких
условиях

как проверим

Мера отвечает «что применяем», решение – «почему, где, при каких условиях и как проверим»



Из чего состоит D-*

12 / 50

D-* · форма проектного решения

поле – что в нём должно быть

КОНТЕКСТ И ПРОБЛЕМА

что произойдёт без решения; какой актив под угрозой

ОБОСНОВАНИЕ

почему этот способ подходит к угрозе и архитектуре

СВЯЗИ

какие T-* решение ограничивает, какие SR-* обеспечивает

ОГРАНИЧЕНИЯ

что решение не закрывает или закрывает частично

РЕШЕНИЕ И ЗАЩИТНЫЕ МЕРЫ

где применяется контроль, какие сведения использует, как реагирует на отказ

СУЩЕСТВЕННАЯ АЛЬТЕРНАТИВА

один реалистичный вариант и причина отказа от него

ПРЕДПОЛОЖЕНИЯ

при каких проверяемых условиях решение работает

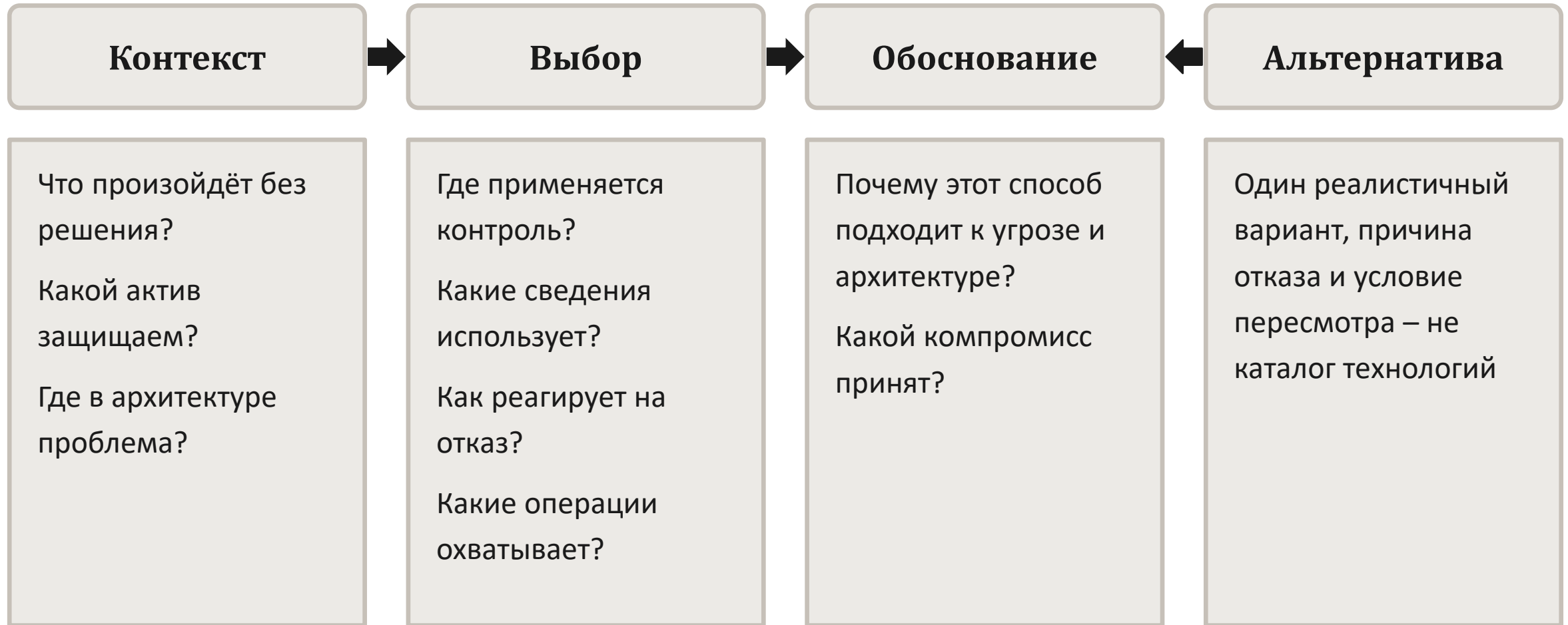
БУДУЩАЯ ПРОВЕРКА

условие → действие → ожидаемый наблюдаемый результат



Контекст, выбор, обоснование

13 / 50





Предположение: когда решение работает?

14 / 50

Предположение решения

– проверяемое условие, при котором выбранная мера должна обеспечивать ожидаемое свойство.

Проверяемые предположения

РЕШЕНИЕ: СРОК ССЫЛКИ СВЕРЯЕТСЯ ПО ВРЕМЕНИ

предположение: часы серверов синхронизированы

РЕШЕНИЕ: ДОСТУП ПО ГРУППЕ КОРПОРАТИВНОГО КАТАЛОГА

предположение: каталог актуален, уволенные удаляются

СЛАБАЯ ФОРМУЛИРОВКА

«Пользователи ведут себя правильно» – проверять нечего: это надежда, а не условие

**Предположение должно быть проверяемым;
надежда не является инженерным условием**



Ограничение: чего решение не обещает?

15 / 50

Ограничение решения – явно обозначенная ситуация или класс угроз, которые решение не закрывает либо закрывает только частично.

РЕШЕНИЕ

Резервное копирование



НЕ ОБЕЩАЕТ

не обеспечивает работу сервиса во время восстановления

РЕШЕНИЕ

Шифрование канала



НЕ ОБЕЩАЕТ

не защищает данные после того, как их легитимно получила конечная система

**Ограничение не делает решение плохим:
оно честно задаёт остаточную область**



Предположение, требование или ограничение?

16 / 50

«Часы серверов синхронизированы»

ПРЕДПОЛОЖЕНИЕ

внешний факт, на котором держится механизм

«Сервис доступен только по защищённому соединению»

ТРЕБОВАНИЕ

обязательное свойство продукта

«Решение не мешает владельцу самому переслать ссылку»

ОГРАНИЧЕНИЕ

область, которую решение не закрывает

«Администратор СУБД хранит пароль вне репозитория»

ТРЕБОВАНИЕ К СРЕДЕ или ПРЕДПОЛОЖЕНИЕ

зависит от того, обязательно ли правило и кто его обеспечивает

**Критичное условие среды нельзя спрятать в предположение,
чтобы снять с команды ответственность**



Секция 3

От угрозы к механизму: собираем D-01

Правдоподобная мера ещё не означает, что заявленная угроза закрыта



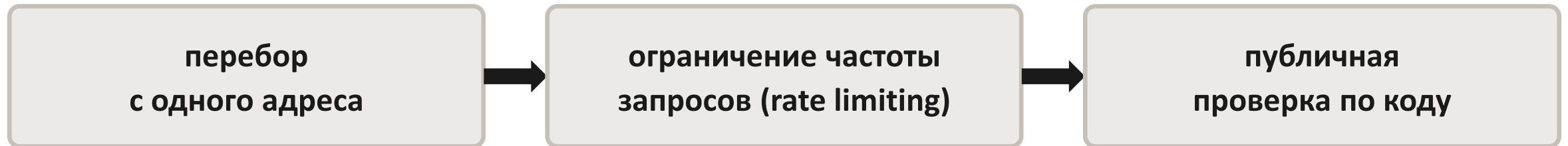
Первая идея: ограничим частоту запросов

18 / 50

Исходная конструкция: код проверки – шесть цифр, выдаются подряд



Мера



не больше заданного числа запросов с одного сетевого адреса

Мера полезна: она действительно замедляет перебор



Почему одной меры недостаточно?

19 / 50

Как вы попробуете обойти эту меру?

Много источников

Запросы распределяются между многими адресами – лимит на один адрес их не суммирует

НАРУШЕНО ПРЕДПОЛОЖЕНИЕ

запросы злоумышленника приходят с одного адреса

Предсказуемый код

Коды выдаются подряд: соседние значения почти наверняка действующие, перебор сужается

НАРУШЕНО ПРЕДПОЛОЖЕНИЕ

код нельзя угадать без массового перебора

Лишние сведения

Лимит не меняет ответ: каждый найденный код раскрывает всё, что сервер возвращает

МЕРА НЕ КАСАЕТСЯ

объёма данных в ответе



D-01 v1 состоит из согласованных мер

20 / 50

Непредсказуемый код

достаточной длины, не связан с порядком реестра

ПРОТИВ

перебора соседних кодов

+

Минимальный ответ

сервер возвращает только статус, тип и срок действия

ПРОТИВ

раскрытия лишних сведений

+

Ограничение частоты

остаётся дополнительным барьером

ПРОТИВ

массовых запросов



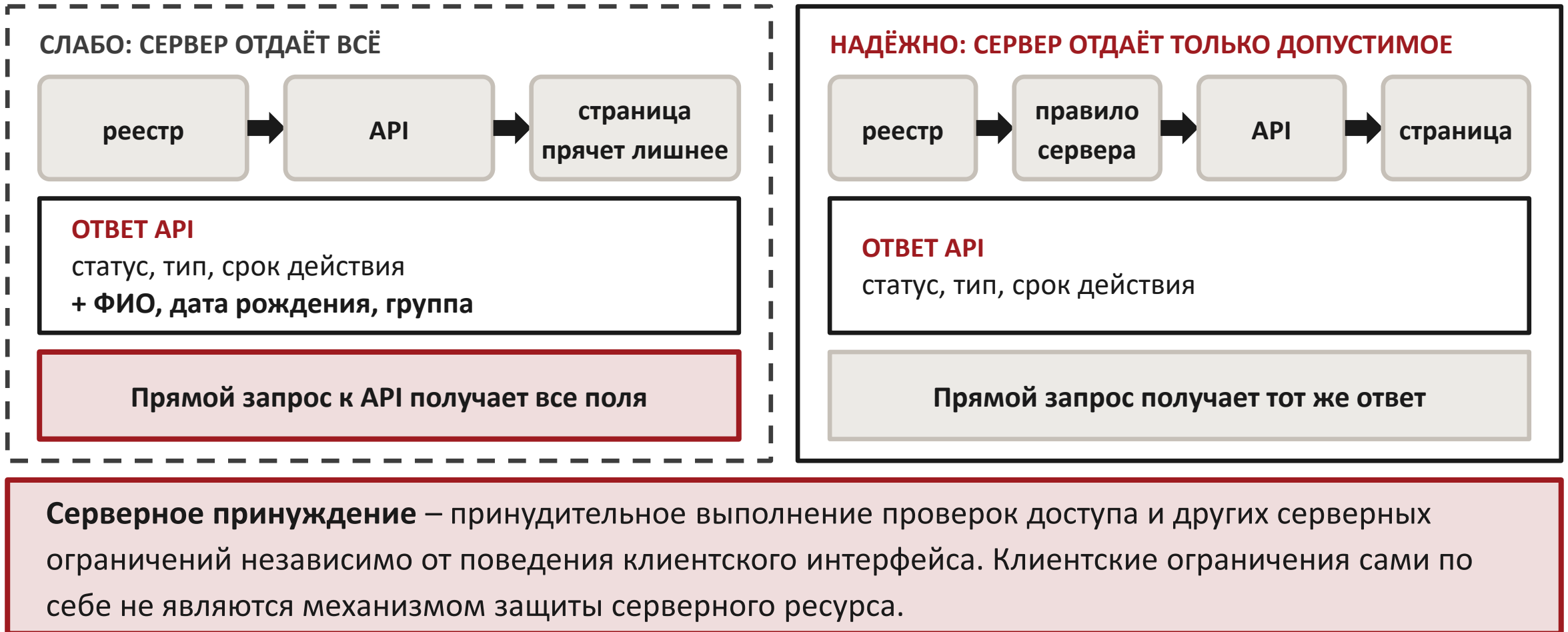
D-01 v1 – одно решение для T-01 / SR-01

**Одна мера не обязана обеспечивать всё:
D-* может быть композиционным**



Сервер должен ограничивать сам ответ

21 / 50





На чём держится D-01 v1 и чего оно не закрывает?

22 / 50

Предположения – на чём держится

генератор кодов обеспечивает достаточную
непредсказуемость

коды не попадают в общедоступные журналы

нет другого интерфейса проверки, отдающего
больше данных

Ограничения – чего не обещает

владелец может сам передать код третьему лицу

компрометация устройства владельца – вне этой
меры

полномочия оператора регулируются отдельным
решением

Существенное предположение попадает в будущую проверку или в явное условие эксплуатации

**Явные границы делают решение
проверяемым и пересматриваемым**



D-01 v1. Полностью заполненная карточка

23 / 50

D-01 · публичная проверка справки по коду

v1 – до обзора решения

КОНТЕКСТ И ПРОБЛЕМА

Организация без аутентификации проверяет справку по коду; короткий последовательный код перебирается

РЕШЕНИЕ И ЗАЩИТНЫЕ МЕРЫ

Непредсказуемый код достаточной длины; сервер отвечает минимумом; ограничение частоты запросов

ОБОСНОВАНИЕ

Подбор становится практически бесполезным, а найденный код раскрывает минимум сведений

СУЩЕСТВЕННАЯ АЛЬТЕРНАТИВА

Проверка только для аутентифицированных организаций. Отклонена: меняет публичный сценарий

СВЯЗИ

T-01 – перебор кодов и раскрытие сведений
SR-01 – устойчивость к подбору и минимум раскрытия

ПРЕДПОЛОЖЕНИЯ

Генератор кодов непредсказуем; коды не попадают в журналы; других интерфейсов проверки нет

ОГРАНИЧЕНИЯ

Не мешает владельцу передать код; не защищает при компрометации его устройства

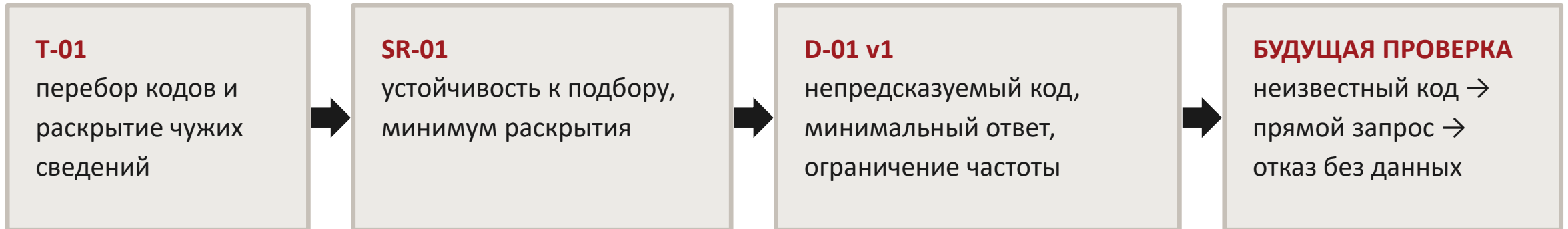
БУДУЩАЯ ПРОВЕРКА

Неизвестный, изменённый или истёкший код → прямой запрос к API → отказ без персональных данных



Теперь цепочка читается в обе стороны

24 / 50



➔ **ПРЯМОЕ ЧТЕНИЕ:** какое свойство ограничивает угрозу → каким механизмом → каким наблюдаемым результатом

⬅ **ОБРАТНОЕ ЧТЕНИЕ:** зачем эта проверка → какое решение подтверждает → какое свойство и путь угрозы за ним

**Чтение проверяет связность известной цепочки,
но не находит путь ущерба, которого нет в модели**



Секция 4

Критерий, будущая проверка и свидетельство

План проверки, выполненная проверка и свидетельство – разные состояния работы



Критерий, будущая проверка и свидетельство

26 / 50

Критерий SR-*

какое наблюдаемое поведение свойства считается приемлемым

уже есть: лекция 02

Проверка D-*

каким сценарием после реализации проверим выбранный механизм

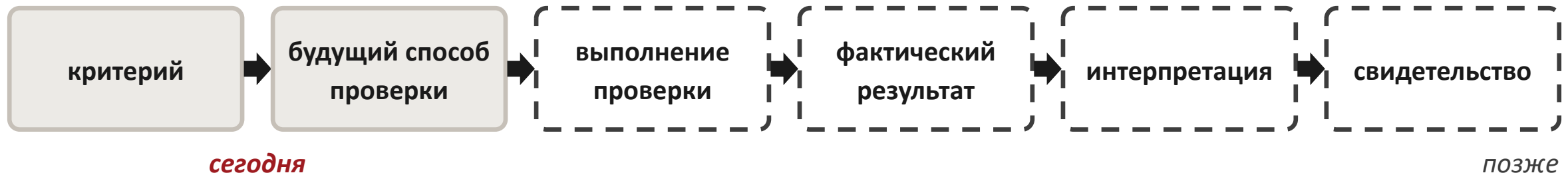
формулируем сегодня

Свидетельство

что реально получено на определённой версии и как это интерпретировано

после реализации

Путь от плана к свидетельству – как на лекции 02

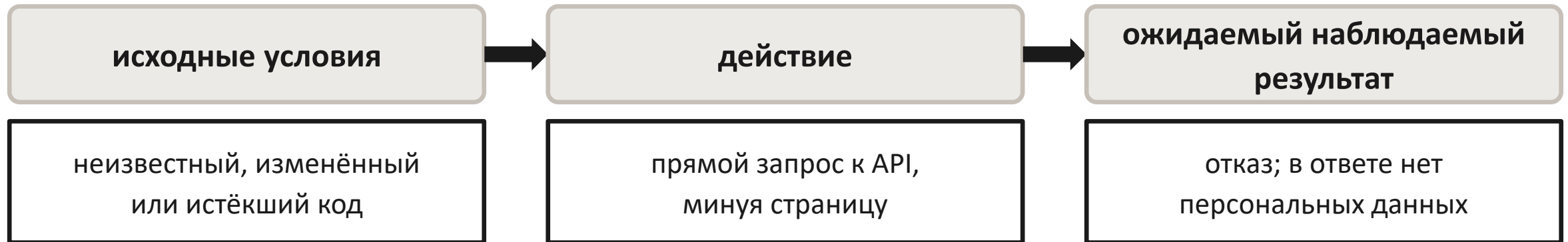




Будущая проверка выбранного механизма

27 / 50

Будущая проверка – заранее определённый сценарий проверки проектного решения D-* или обеспечиваемого им свойства: условия, действие и ожидаемый наблюдаемый результат. Проверка опирается на критерий приёмки связанного SR-* и уточняет, как проверить выбранный механизм и существенные условия его применения. План проверки не является фактически полученным свидетельством.



пример для D-01 v1

Условия, специфичные для механизма: прямое обращение, повтор, изменение состояния, сбой между шагами – если существенны

Рабочее определение курса



Что будущая проверка добавляет к критерию?

28 / 50

Какие условия проверяют именно механизм D-01 v1?

прямой запрос к API

применимо: ответ ограничивает сервер, а не страница

повторяемые запросы

применимо: срабатывает ограничение частоты

изменение состояния

применимо: отозванная или истёкшая справка

альтернативный путь к тем же
данным

применимо: нет ли другого интерфейса с полным ответом

сбой между двумя шагами

несущественно: проверка по коду – одна операция

**Хорошая проверка отличает корректную реализацию D-*
от формально похожей, но обходной**



Секция 5

Принципы безопасного проектирования

Принцип не выдаёт готовое решение – он задаёт вопрос к уже выбранному



Пять принципов – пять вопросов

30 / 50

**Минимальные
привилегии**

**Сколько прав
действительно
нужно?**

**Безопасные
значения
по умолчанию**

**Что будет, если
разрешение не
определено?**

**Полное
посредни-
чество**

complete mediation

**Проверяется ли
каждый
существенный
путь?**

**Разделение
обязанностей**

**Может ли один
субъект
выполнить и
скрыть
критичное
действие?**

**Минимизация
поверхности
воздействия**

attack surface

**Что можно
вообще убрать?**

**Принципы не заменяют T, SR и D:
они проверяют качество выбранного решения**



Минимальные привилегии: сколько прав нужно?

31 / 50

Минимальные привилегии

– принцип проектирования: субъект получает только те права, которые необходимы для его функции, и не больше.

Три измерения прав

НАБОР ПРАВ

какие операции разрешены

ОБЛАСТЬ ДАННЫХ

к каким объектам и полям

ВРЕМЯ ДЕЙСТВИЯ

как долго права существуют

ПРИМЕР: НОЧНОЙ ПРОЦЕСС ФОРМИРОВАНИЯ ОТЧЁТА

набор прав – только чтение, без записи и удаления

область данных – две нужные таблицы, а не вся база

время действия – учётные данные выдаются на время задачи

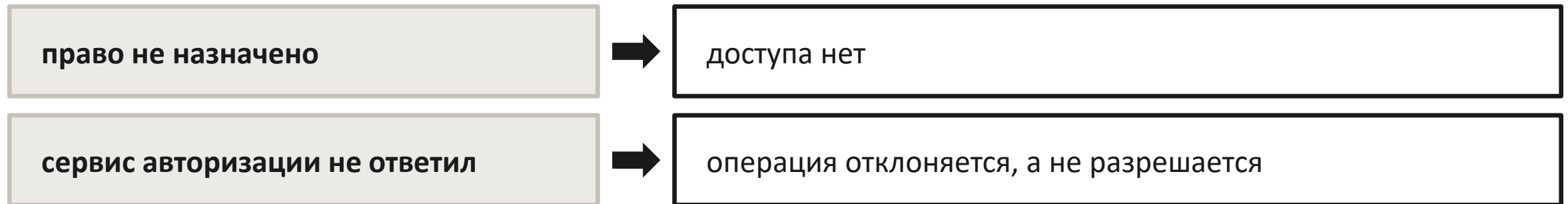


Безопасные значения по умолчанию

32 / 50

Безопасные значения по умолчанию – принцип выбора безопасного исходного поведения без дополнительных действий пользователя; для доступа – отсутствие разрешения означает отказ. Безопасное поведение при ошибке также должно быть определено явно для конкретной системы.

Что происходит при неопределённости?



Безопасное поведение при ошибке не означает «всегда отказать»: постоянная недоступность продукта – тоже вред, поведение проектируют для конкретной системы

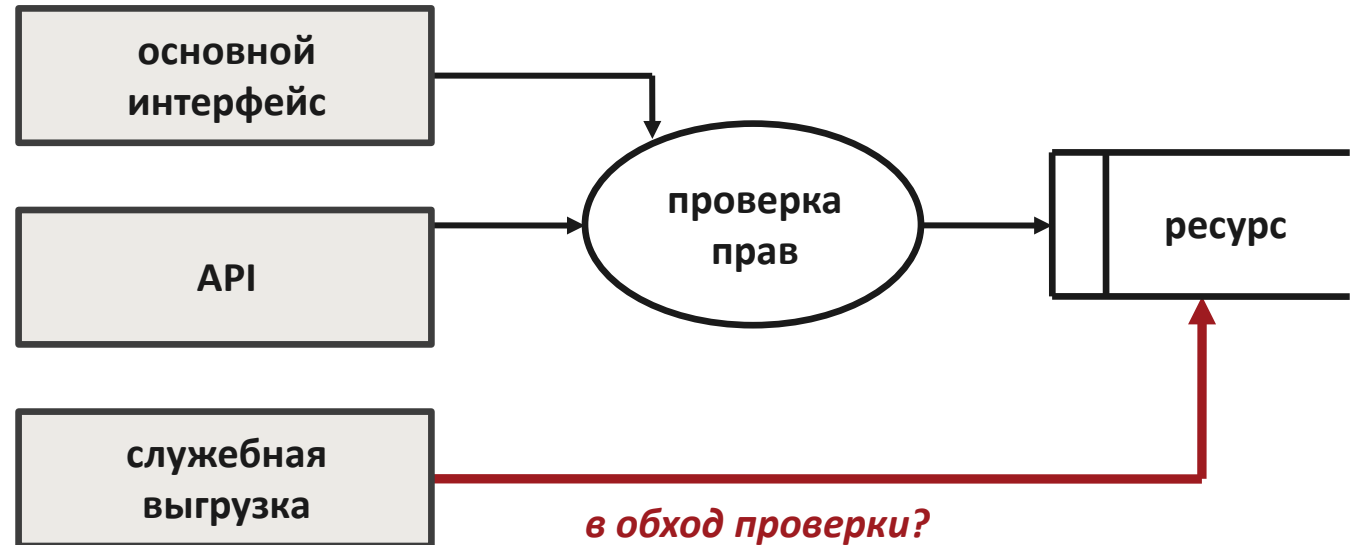


Полное посредничество: проверен ли каждый путь?

33 / 50

Полное посредничество

– принцип проектирования: каждое обращение к защищаемому ресурсу проходит проверку прав без обходных путей и без необоснованного повторного использования устаревшего решения о доступе.



**Проходит ли проверку каждый существенный путь –
и не устарело ли уже принятое решение о доступе?**



Ещё два вопроса к решению

34 / 50

Разделение обязанностей

– распределение критичных действий так, чтобы один субъект не мог единолично выполнить и скрыть всю опасную операцию.

Может ли один субъект выполнить и скрыть критичное действие?

ПРИМЕР

платёж создаёт один сотрудник, подтверждает другой

Минимизация поверхности воздействия

– сокращение числа доступных функций, интерфейсов, полномочий и компонентов, которые могут быть использованы для нарушения безопасности.

Что не нужно основному сценарию?

ПРИМЕР

отладочный интерфейс отключён в рабочей среде

**Применимость зависит от угрозы, цены действия и стоимости:
второй подтверждающий нужен не везде**



Прогоним D-01 v1 через пять вопросов

35 / 50

D-01 v1

МЕРЫ

непредсказуемый код
минимальный ответ
сервера
ограничение частоты

ПРЕДПОЛОЖЕНИЯ

генератор, журналы, другие
интерфейсы

Сколько прав нужно?

ПОДТВЕРЖДАЕТ процесс проверки читает
только поля публичного ответа

Что при неопределённости?

ПОДТВЕРЖДАЕТ неизвестный код не
раскрывает никаких данных

Каждый ли путь проверен?

УТОЧНЯЕТ ищем другие интерфейсы к
реестру – это предположение

Один субъект всё сделает?

НЕ ЦЕНТРАЛЬНЫЙ для публичной проверки
разделение не главный вопрос

Что можно убрать?

УТОЧНЯЕТ лишние поля ответа и ненужные
интерфейсы

Не каждый принцип обязан породить новую меру: он полезен,
если подтверждает решение, находит разрыв или уточняет границы



Секция 6

Обзор решения: ищем контрпример

Хорошее решение выдерживает не только объяснение автора, но и попытку его сломать



Что такое обзор проектного решения

37 / 50

Обзор проектных решений безопасности

– компактный анализ проектного решения: закрываемые угрозы, предположения, ограничения и слабые места. Проводится для проверки обоснованности решения.

Три вопроса обзора

1

Обеспечивает ли решение заявленное свойство?

2

На каких предположениях оно держится?

3

Какой альтернативный путь или контрпример его ломает?

вход: T-*, SR-*, D-*

обзор

выход: изменения
в артефактах

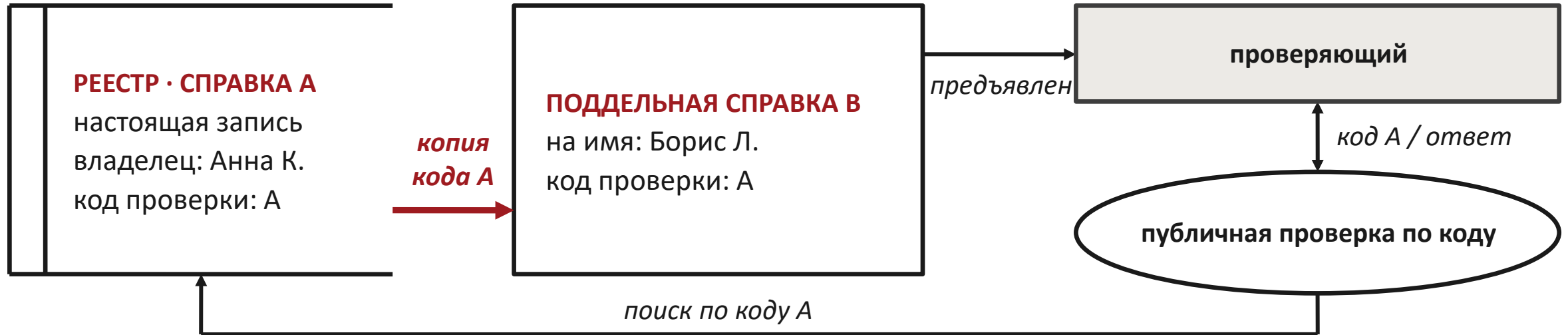
Это не поиск дефектов реализации: кода может ещё не быть

Рабочее определение курса



Контрпример: чужой код на поддельной справке

38 / 50



Код А существует и действителен?

да – это D-01 v1 проверяет

Код А относится к документу В?

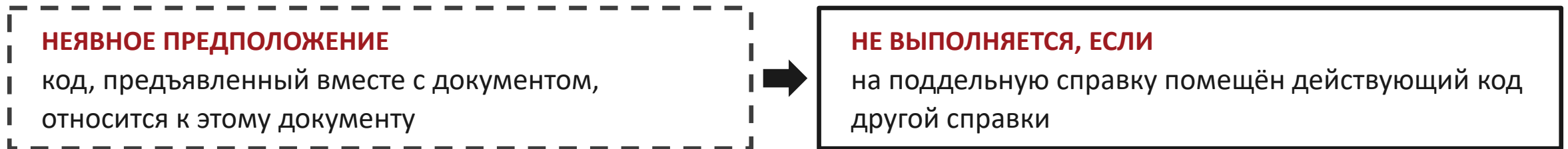
D-01 v1 этого не проверяет

Т-02 – предъявитель использует действующий код другой справки, чтобы подтвердить поддельный документ



Модель угроз и требования нужно расширить

39 / 50



Т-02 – предъявитель использует действующий код другой справки, чтобы подтвердить поддельный документ

НОВОЕ ТРЕБОВАНИЕ · SR-02

публичная проверка позволяет установить, что действующий код относится к предъявленному документу; несоответствующая пара «код + проверяемые реквизиты» не подтверждается



Два способа обеспечить SR-02

40 / 50

Вариант А. Сервер показывает реквизиты

проверяющий вводит код, сервер показывает ограниченный набор реквизитов, проверяющий сверяет их с документом

КОМПРОМИСС

- + проще для проверяющего
- реквизиты видит любой, у кого есть код

Вариант В. Сервер сверяет реквизиты

проверяющий вводит код и реквизиты предъявленного документа, сервер отвечает «совпадает / не совпадает»

КОМПРОМИСС

- + реквизиты не раскрываются
- больше ввода, выбор реквизитов критичен

**Какой вариант лучше согласуется с минимизацией раскрытия
и какой новый риск он создаёт?**



D-01 v2. Решение после обзора

41 / 50

D-01 · публичная проверка справки по коду

v2 – после обзора · контекст как в v1

СВЯЗИ

T-01 / SR-01 – перебор и избыточное раскрытие
T-02 / SR-02 – подмена документа чужим кодом

РЕШЕНИЕ И ЗАЩИТНЫЕ МЕРЫ

Меры v1 сохраняются. Добавлено: проверяющий вводит код и реквизиты документа, сервер отвечает «совпадает / не совпадает»

ОБОСНОВАНИЕ

Код связывается с предъявленным документом, а реквизиты не раскрываются тому, кто их не знает

АЛЬТЕРНАТИВА И ПЕРЕСМОТР

Сервер показывает реквизиты: проще, но раскрывает больше. Пересмотр – подписанный документ или QR-код

БУДУЩАЯ ПРОВЕРКА – ДОБАВЛЕНО

Чужой действующий код + реквизиты другого документа → «не совпадает»
Серия запросов с одним кодом и разными реквизитами → после порога отказ независимо от реквизитов

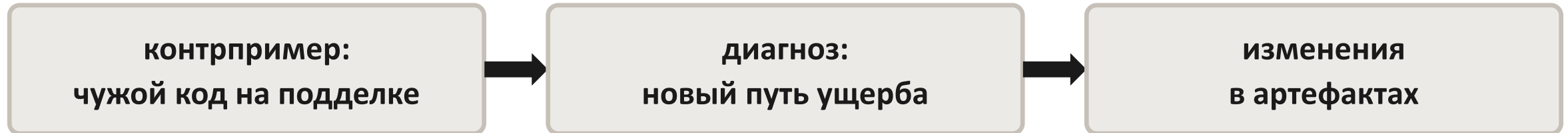
ОГРАНИЧЕНИЯ

Ответ «совпадает / не совпадает» – возможный оракул для подбора реквизитов
Сверяются только выбранные реквизиты: остальное содержание можно подделать
Личность предъявителя не подтверждается



Обзор завершён, когда изменены артефакты

42 / 50



Что изменилось в нашем примере

модель угроз: + T-02	требования: + SR-02	решение: D-01 → v2
обоснование: варианты А и В	ограничения: оракул, поля, личность	будущая проверка: + два сценария

**Замечание без изменения артефактов –
ещё не завершённый обзор**



Секция 7

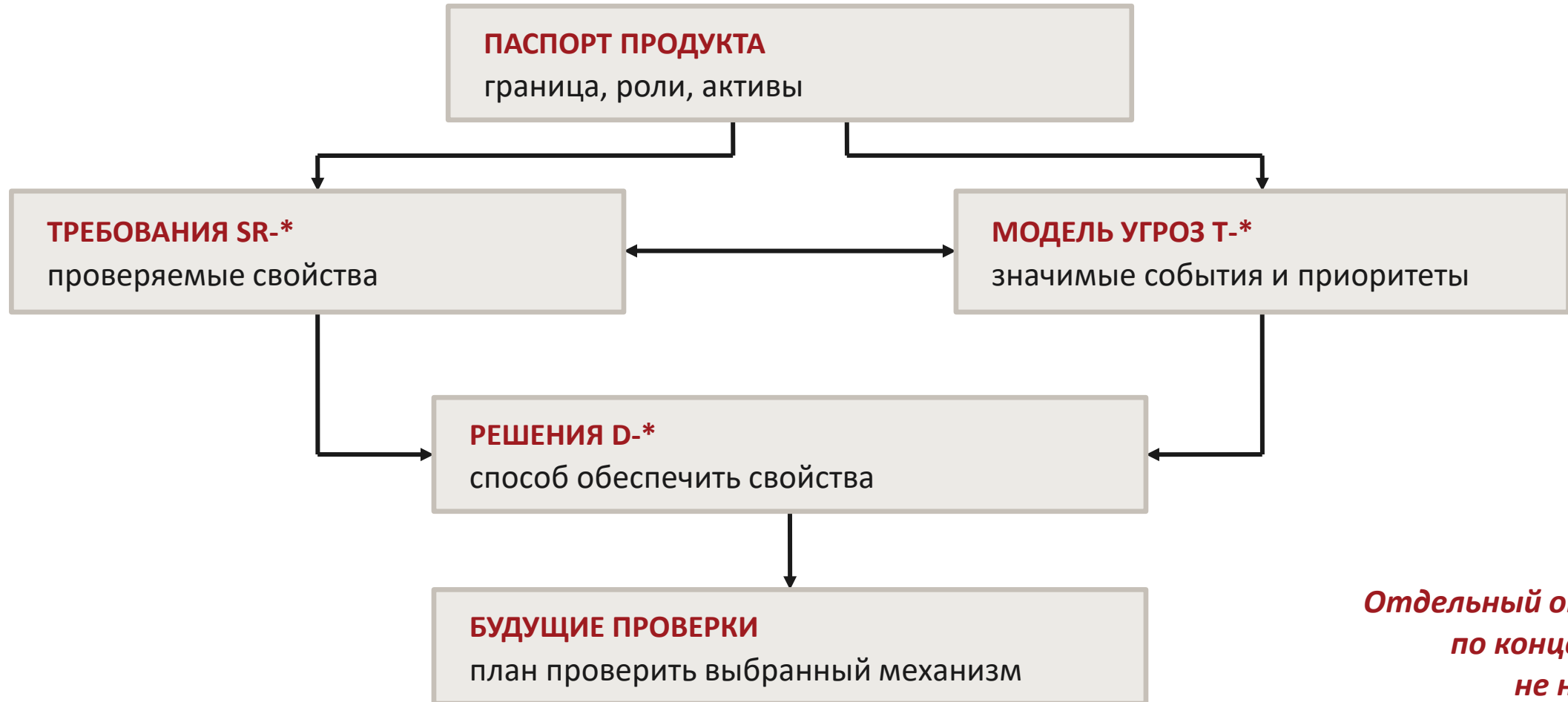
Концепция безопасности и ДЗ-1

К контролю важна не стопка документов, а согласованная система связей



Концепция уже существует в ваших артефактах

44 / 50

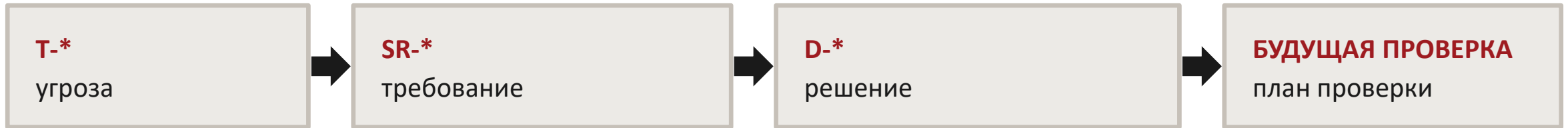


*Отдельный отчёт
по концепции
не нужен*



Согласованность проверяется переходами

45 / 50



➡ **ПРЯМОЕ ЧТЕНИЕ:** для каждой приоритетной угрозы – свойство, механизм, план проверки

⬅ **ОБРАТНОЕ ЧТЕНИЕ:** у каждой проверки и решения – ради какого свойства и угрозы

НЕ КОЛИЧЕСТВО ЗАПИСЕЙ

одно D-* может обеспечивать несколько свойств и ограничивать несколько угроз; ориентир 2-3 решений – не квота

ОДНИ И ТЕ ЖЕ СУЩНОСТИ

роли, активы и архитектурная граница совпадают во всех артефактах и относятся к одной версии продукта



База

- связная концепция для всего приоритетного набора
- содержательные D-*: выбор, контекст, обоснование, ограничения, будущая проверка

Глубже: согласованность

- свой нетривиальный контрпример
- исходное предположение → сценарий, где оно не выполняется
- последствия для T, SR, D и уточнение цепочки и проверки

на лекции: T-02 и SR-02

Глубже: решение

- два применимых способа для одного свойства
- компромисс, границы, обоснование выбора
- условие пересмотра, проверка с учётом ограничения

на лекции: варианты A и B

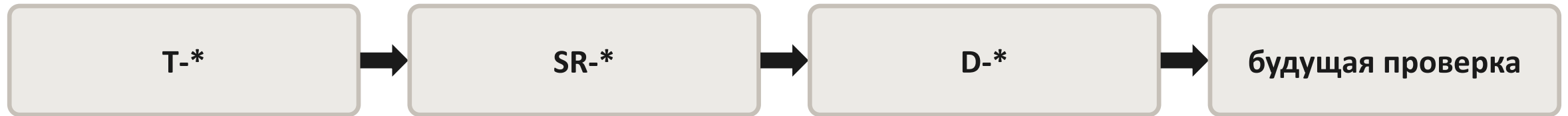
Не нужны отдельный отчёт, искусственная ошибка или реализация двух вариантов. Повторение разобранного на лекции примера повышенный уровень не подтверждает



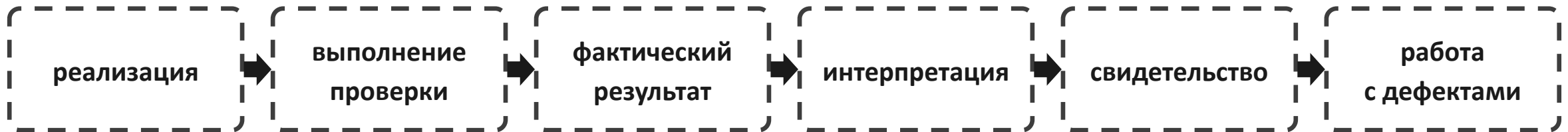
Граница результата лекции 04

47 / 50

Сегодня



Позже



ПОЗЖЕ

Лекция 04 завершает охват ДЗ-1.

Лекция 05 открывает следующий раздел и в ДЗ-1 не входит



Пять выводов лекции

48 / 50

- 1** D-* – обоснованный выбор способа обеспечить свойство, а не название технологии
- 2** Мера работает при предположениях и имеет ограничения – их записывают явно
- 3** Будущая проверка – план проверки механизма, а не свидетельство
- 4** Принципы – вопросы к решению, а не список обязательных механизмов
- 5** Хороший контрпример меняет T, SR, D или будущую проверку

Результаты лекции на примере: записать D-* – экран 23 · будущая проверка – экраны 27 и 41 · контрпример и уточнение – экраны 38-41



Следующий шаг – семинар 04 и ДЗ-1

49 / 50

На семинаре 04

- разобрать решения учебного кейса
- записать хотя бы одно D-* своего проекта
- связать его с T-* и SR-*, задать будущую проверку
- найти разрывы приоритетного набора
- начать CONTRIBUTIONS.md

К предварительной сдаче ДЗ-1

- связать весь приоритетный набор
- уточнить D-* и будущие проверки
- подготовить минимальную запускаемую основу
- зафиксировать версию: commit или tag ek1

Пока не требуется

- полная реализация мер
- выполненные проверки и свидетельства
- отдельное D-* на каждую угрозу
- матрица трассировки, отдельный отчёт

Условия сдачи – по действующему регламенту ДЗ-1 в репозитории курса

